MH Recruiting Workspace - Nichtfunktionale Anforderungen

Version: 1.0 · **Stand:** 28. September 2026 · **Zweck:** Separates Qualitäts- und Betriebsdokument, unabhängig von Modulen, Epics und Use Cases.

Geltungsbereich und Verbindlichkeit

Diese Anforderungen betreffen die öffentliche Website, Registrierung, Workspace, KI-Erstellung, E-Mail und Zahlungsabwicklung für EU-Firmen. **Ist-Stand** beschreibt den lokalen Prototyp. **Zielwert** ist ein vorgeschlagener Abnahmemaßstab für einen Pilotbetrieb, kein bereits erreichter SLA-Wert. P0 muss vor echten zahlenden Kunden nachgewiesen sein; P1 vor einem breiteren Pilot; P2 kann später folgen. Werte ohne Lastprofil oder Hostingentscheidung sind zu bestätigen.

Sicherheit und Identität

NFA-01 Transport und Sitzungen · P0

Anforderung: Produktionszugriffe ausschließlich über HTTPS; Session-Cookies HttpOnly, Secure und SameSite; keine Browser-Speicherung von Sitzungstokens. Zustandsänderungen sind gegen CSRF geschützt. **Abnahmevorschlag:** Automatisierter Test prüft Cookie-Flags, Origin-/CSRF-Ablehnung und fehlenden Zugang bei abgelaufener Sitzung; externer HTTPS-Check prüft TLS-Konfiguration und Weiterleitung. **Ist-Stand:** Cookie-/CSRF-Mechanik implementiert und lokal getestet; öffentliche HTTPS-Umgebung fehlt.

NFA-02 Authentifizierung und Wiederherstellung · P0

Anforderung: Starke Passwörter, Ratenlimits, Einmallinks, MFA für Firmen-Admins, Einmal-Recovery-Codes und sichere Sitzungsrotation. Ein verlorener zweiter Faktor darf nicht allein per E-Mail umgangen werden. **Abnahmevorschlag:** Tests für Brute-Force-Grenzen, Linkablauf/-Wiederholung, TOTP-Replay, Session-Widerruf und manuell freigegebenen Recovery-Prozess. **Ist-Stand:** Technische Kontrollen vorhanden; Prozess für Verlust von Authenticator **und** Recovery-Codes fehlt.

NFA-03 Mandantentrennung und Rechte · P0

Anforderung: Alle Firmenobjekte und Token-/Zahlungsdaten sind strikt auf das zugehörige Unternehmen begrenzt; Rollen werden serverseitig geprüft. **Abnahmevorschlag:** Negativtests für Lesen, Schreiben, Export, Generierung und Abrechnung mit Konten zweier Firmen; fremde Objekt-IDs liefern keine Daten. Rechteänderungen greifen ohne Frontend-Vertrauen. **Ist-Stand:** API-Prüfungen und Isolationstests vorhanden; vor Produktion ergänzender unabhängiger Sicherheitstest empfohlen.

NFA-04 Geheimnisse und Schlüssel · P0

Anforderung: Stripe-, Gmail-, KI-, MFA- und Datenbank-Geheimnisse dürfen nie in Frontend, Repository, Logs, Dokumentation oder Chat erscheinen. Zugriff nur serverseitig, minimal berechtigt; Rotation muss möglich sein. **Abnahmevorschlag:** Secret-Scan für Build/Repository/Logs; dokumentierte Rotation; Dateirechte oder Secret-Manager geprüft; Produktionsschlüssel vom Test getrennt. **Ist-Stand:** Lokale private Konfiguration mit Dateirechten 0600; produktiver Secret-Manager und Rotation offen. Ein Stripe-Testschlüssel erschien früher im Chat und sollte ersetzt werden.

NFA-05 Nachvollziehbarkeit sicherheitsrelevanter Aktionen · P1

Anforderung: Authentifizierung, Berechtigungsfehler, Admin-Änderungen, Zahlungsereignisse und Tokenbuchungen sind nachvollziehbar, ohne Passwörter, vollständige Briefings oder Zahlungskartendaten zu protokollieren. **Abnahmevorschlag:** Protokollschema mit Ereignis-ID, Zeit, Akteur, Firma und Ergebnis; Zugriff und Aufbewahrung definiert; Stichprobe zeigt keine Geheimnisse. **Ist-Stand:** Aktivitäts-, Historien- und Tokenledgerdaten existieren; zentrales Audit/Monitoring fehlt.

Zahlung, Guthaben und wirtschaftliche Kontrolle

NFA-06 Zahlungsintegrität · P0

Anforderung: Nur authentische, zur Umgebung passende Stripe-Ereignisse vergeben Abos und Tokens; wiederholte, verspätete oder vertauschte Ereignisse erzeugen keine Doppelbuchung. **Abnahmevorschlag:** End-to-End-Testmatrix für Zahlung, 3D Secure, Abbruch, fehlgeschlagene Verlängerung, Webhook-Wiederholung, Rückerstattung und Dispute; Soll- und Ist-Buchungen stimmen überein. **Ist-Stand:** Signatur-, Betrags- und Idempotenzlogik lokal getestet; echte Stripe-Testmatrix offen.

NFA-07 Tokenledger und Parallelität · P0

Anforderung: Guthaben kann nie negativ werden. Mehrere Aufladungen addieren sich; jeder erfolgreiche Generierungsauftrag belastet genau einmal, fehlgeschlagene Aufträge gar nicht. Monatliche und gekaufte Tokens bleiben getrennt. **Abnahmevorschlag:** Nebenläufigkeitstests mit konkurrierenden Käufen/Generierungen; Ledger lässt jede Saldoänderung erklären; Saldo auf Dashboard stimmt nach Aktualisierung mit Backend überein. **Ist-Stand:** Transaktionale Buchung und Tests vorhanden; Last unter realem Zahlungs-/KI-Betrieb nicht gemessen.

NFA-08 Preis- und Kostenklarheit · P0

Anforderung: Netto-Tarif, enthaltenes Guthaben, Tokenpreis, Abrechnungsintervall, Kündigungswirkung und Steuerbetrag sind vor Kauf transparent. Kein automatischer Nachkauf und keine versteckten KI-Kosten für Kunden. **Abnahmevorschlag:** Veröffentlichte Angaben, Stripe-Checkout-Preis, Backend-Katalog und Rechnung stimmen in EUR überein; Testfall belegt explizite Zustimmung zu kostenpflichtigem Auftrag. **Ist-Stand:** Monatlicher Katalog und 50-Token-Bestätigung vorhanden. Diskutierte günstigere/mehrjährige Tarife sind nicht umgesetzt; Preisentscheidung offen.

NFA-09 Kostenobergrenze des KI-Anbieters · P1

Anforderung: Der Plattformbetreiber kann KI-Verbrauch und Grenzkosten je Auftrag beobachten und Ausreißer begrenzen. Fehlversuche dürfen nicht unbemerkt wiederholt werden. **Abnahmevorschlag:** Reale Stichprobe mit mindestens 30 repräsentativen Briefings; Eingabe-/Ausgabe-Tokens, Fehlerrate, Kosten und Qualitätsbewertung pro Fall; definierter Alarm-/Budgetwert vor Livebetrieb. **Ist-Stand:** Eingabe und Ausgabe begrenzt, store=false, Nutzungsdaten gespeichert; echter Anbieteraufruf und Kostenmessung fehlen.

Datenschutz und Datenlebenszyklus

NFA-10 EU-Datenverarbeitung und Verträge · P0

Anforderung: Für personenbezogene Bewerbungs- und Unternehmensdaten sind Datenflüsse, Auftragsverarbeiter, Speicherorte und internationale Übermittlungen dokumentiert und vertraglich geprüft; EU-Regionen nicht allein aus einer URL behaupten. **Abnahmevorschlag:** Datenflussübersicht, AV-Verträge, Hosting-/Mail-/KI-Regionnachweise und veröffentlichte Datenschutzhinweise freigegeben. **Ist-Stand:** EU-Firmenmarkt und optionale EU-KI-URL vorgesehen; Anbieter-, Regions- und Vertragseignung offen.

NFA-11 Datensparsamkeit und Löschung · P0

Anforderung: Nur benötigte Personen-, Firmen-, Briefing-, Zahlungs- und Nutzungsdaten speichern; Aufbewahrungsfristen und Lösch-/Exportwege je Datenart definieren. Zahlungsdetails bleiben bei Stripe. **Abnahmevorschlag:** Dateninventar mit Zweck, Rechtsgrundlage/Vertrag, Frist und Löschtest; Löschanforderung kann ohne Verlust gesetzlich nötiger Rechnungsdaten umgesetzt werden. **Ist-Stand:** Kartendaten werden nicht lokal erfasst; geregelter Produktions-Löschprozess fehlt.

NFA-12 Backup und Wiederherstellung · P0

Anforderung: Produktionsdatenbank, verschlüsselte MFA-Schlüssel und Konfiguration müssen gesichert und gemeinsam wiederhergestellt werden; Backups sind verschlüsselt und zugriffsbeschränkt. **Abnahmevorschlag:** Vorgeschlagene Pilotziele: RPO höchstens 24 Stunden und RTO höchstens 8 Stunden, anhand eines dokumentierten Restore-Tests bestätigt. Vor Vertragszusage mit Hostingkosten und Kundenerwartung abstimmen. **Ist-Stand:** Lokale SQLite-Dateien; keine produktive Backup-/Restore-Strecke.

Zuverlässigkeit und Betrieb

NFA-13 Verfügbarkeit und Störungen · P1

Anforderung: Zahlungs-, Registrierungs- und Workspace-Fehler sind erkennbar; Nutzer erhalten eine ehrliche Statusmeldung und können abgebrochene Schritte fortsetzen. **Abnahmevorschlag:** Pilotziel 99,5 % monatliche Verfügbarkeit außerhalb angekündigter Wartung; synthetische Prüfung für Landing, API und Login; dokumentierter Eskalationsweg. Ziel vor Zusage bestätigen. **Ist-Stand:** Health-Endpunkt und fortsetzbares Onboarding vorhanden; Monitoring, Alarmierung und Incident-Prozess fehlen.

NFA-14 Antwortzeit · P1

Anforderung: Kernseiten und gewöhnliche API-Aktionen reagieren unter definierter Pilotlast flüssig; KI-Generierung zeigt Fortschritt/Fehler statt still zu hängen. **Abnahmevorschlag:** Nach Festlegung des Lastprofils p95 für einfache API-Aufrufe < 1 s und für Seiteninteraktion < 2 s, gemessen ohne externe Stripe-/KI-Wartezeit. Generierung hat begrenzte Laufzeit und verständlichen Timeout. **Ist-Stand:** Kein reproduzierbarer Lasttest. KI-Netzwerk-Timeout ist begrenzt; synchrone SQLite-Schreibtransaktion während Anbieteraufruf limitiert Parallelität.

NFA-15 Skalierung und Nebenläufigkeit · P1

Anforderung: Gleichzeitige Firmen dürfen sich weder gegenseitig blockieren noch Token falsch buchen; bei Wachstum muss KI-Arbeit aus dem Webrequest in nachvollziehbare Jobs ausgelagert werden. **Abnahmevorschlag:** Repräsentativer Lasttest mit vereinbarter Zahl gleichzeitiger Firmen/Generierungen; kein negativer Saldo, keine verlorenen Jobs, definierte Warteschlangenzeit. Kapazitätsgrenze dokumentieren. **Ist-Stand:** SQLite und synchrone KI-Generierung geeignet für lokalen Prototyp; Pilotlast und Migrationsplan offen.

NFA-16 Externe Ausfälle und Wiederholung · P0

Anforderung: Stripe-, E-Mail- oder KI-Ausfälle führen zu konsistenten Zuständen. Webhooks und Rechnungsnachrichten lassen sich sicher wiederholen; ein fehlgeschlagener KI-Auftrag verbraucht keine MH-Tokens. **Abnahmevorschlag:** Ausfalltests mit Netzunterbrechung und doppelter Zustellung; kein doppelter Guthabeneffekt; Betreiber erkennt ausstehende Rechnungsnachricht und kann zustellen. **Ist-Stand:** Idempotenz-/Rollback-Grundlage vorhanden; operative Replay-/Monitoring-Prozesse und externe End-to-End-Tests fehlen.

NFA-17 Konfiguration und Umgebungen · P0

Anforderung: Entwicklung, Stripe-Test und Produktion sind getrennt; Livefreigabe benötigt geprüfte Steuern, Radar, Rechnung, KI-Qualität, HTTPS, SMTP und rechtliche Inhalte. Demo-Daten dürfen nicht in Produktion gelangen. **Abnahmevorschlag:** Deployment-Checkliste mit Vier-Augen-Freigabe, getrennten Schlüsseln/Datenbanken und automatischen Konfigurationsprüfungen; fehlende Pflichtwerte blockieren Live-Checkout. **Ist-Stand:** Technische Live-Gates vorhanden; Produktionsumgebung und Freigabeprüfung fehlen.

Nutzerqualität und Auffindbarkeit

NFA-18 Barrierefreiheit · P1

Anforderung: Öffentliche Seite, Registrierung, Onboarding und Kern-Workspace sind mit Tastatur und Screenreader bedienbar; Fehler sind verständlich und zugeordnet. **Abnahmevorschlag:** Ziel WCAG 2.2 AA für Kernabläufe; automatisierter Scan plus manueller Tastatur-/Screenreader-Test der vier Hauptabläufe. Ziel als Produktanforderung, noch kein Nachweis. **Ist-Stand:** Semantische Elemente und Statusmeldungen teilweise vorhanden; vollständiges Audit fehlt.

NFA-19 Responsivität und Browser · P1

Anforderung: Kernabläufe sind auf gängigen aktuellen Desktop- und Mobilbrowsern nutzbar; Zahlungsübergang funktioniert nach Rückkehr in derselben Sitzung. **Abnahmevorschlag:** Definierte Browser-/Gerätematrix mit Tests für Landing, Registrierung, MFA, Checkout-Rückkehr, Tokenanzeige und Export. Keine horizontal abgeschnittenen Pflichtaktionen bei 320 px Breite. **Ist-Stand:** Responsive Styles und einzelne Browserprüfungen vorhanden; vollständige Matrix offen.

NFA-20 SEO und öffentliche Inhalte · P1

Anforderung: Nur öffentliche, wahrheitsgemäße Seiten indexierbar; Auth-, Onboarding-, App- und Fehlerseiten bleiben noindex. Canonical, Sitemap, Metadaten und echte 404-Antwort stimmen mit der produktiven Domain überein. **Abnahmevorschlag:** Produktionsbuild mit HTTPS-Domain; automatisierter SEO-Check und Live-Crawl prüfen Titel, Beschreibung, Canonical, Robots, Sitemap, Statuscode und mobile Darstellung. **Ist-Stand:** Prerendering und lokale SEO-Tests vorhanden; öffentliche Domain und Live-Crawl fehlen.

NFA-21 Verständlichkeit und Sprache · P1

Anforderung: Kundenführung ist durchgehend deutsch und erklärt Tokens, Steuer, Rechnung, Kündigung und interne Review-Zustände ohne Fachjargon oder irreführende Leistungsversprechen. **Abnahmevorschlag:** Moderierter Test mit mindestens fünf Zielkunden; jeder kann vor Checkout Gesamtpreis und Tokenwirkung erklären und findet den nächsten Onboarding-Schritt ohne Hilfe. **Ist-Stand:** Deutsche Hauptstrecke vorhanden; einzelne alte Prototyptexte können von realem KI-/Zahlungsstatus abweichen und müssen redaktionell geprüft werden.

Rechtliche und organisatorische Freigabe

NFA-22 Rechnungs- und Steuerqualität · P0

Anforderung: Ausgestellte Rechnungen enthalten echte, für den konkreten Fall notwendige Firmen-, Leistungs-, Zeitraum- und Steuerdaten. Strukturierte E-Rechnungspflichten werden vor echtem Verkauf fachlich geprüft und technisch eingeplant. **Abnahmevorschlag:** Freigabe durch Steuerberatung/Rechnungsverantwortliche anhand deutscher und EU-Auslands-Testfälle; Muster-PDF und gegebenenfalls strukturiertes Format validiert. Fehlende Daten sperren Livebetrieb. **Ist-Stand:** Stripe-PDF-Benachrichtigung implementiert; Ausstellerdaten, Stripe Tax, Musterrechnung und E-Rechnungslösung fehlen.

NFA-23 Produkt- und Supportverantwortung · P0

Anforderung: Betreiber, Kontaktweg, Nutzungsbedingungen, Datenschutz, Rückerstattungs- und Kündigungsprozess sowie Support für gesperrte Konten sind festgelegt und für Kunden zugänglich. **Abnahmevorschlag:** Veröffentlichte, freigegebene Texte und ein durchgespielter Supportfall zu Zahlung, Mailzustellung und MFA-Verlust. **Ist-Stand:** Firmenangaben und Rechtstexte wurden noch nicht geliefert; Supportprozess fehlt.

Vor Livebetrieb zu prüfen

- Zieltarife und Vertragslogik: aktueller Katalog 19/69/149 € monatlich oder 190/690/1.490 € jährlich im Voraus; monatliche Inklusivtokens auch beim Jahresabo, Kündigung zum Ende des bezahlten Zeitraums. Wirtschaftlichkeit und vollständiger Zahlungsdurchlauf vor Livebetrieb prüfen.
- Erwartete Pilotlast: Firmen, aktive Bearbeiter, Kampagnen und gleichzeitige KI-Aufträge pro Monat. Erst dann NFA-14/15 finalisieren.
- Hosting, Datenbank, Backupbudget und gewünschte EU-Datenverarbeitungsregion.
- Geschäftlicher Mailanbieter und Absenderdomain statt persönlichem Gmail.
- Rechtlicher Rechnungsaussteller, Steuerkonfiguration, E-Rechnungsweg und Vertrags-/Datenschutztexte.
- Tatsächliche KI-Qualität, Verbrauch, Zielmarge und maximale Betriebskosten.

Nachweisquellen im Projekt

PROJECT_CONTEXT.md, AUTH_SETUP.md, BILLING_SETUP.md, INVOICE_SETUP.md, TOKEN_PRICING.md, Backend-Tests und Frontend-Build. Diese Spezifikation beschreibt den Stand vom 28.09.2026 und ersetzt keine rechtliche, steuerliche oder produktive Betriebsfreigabe.